Should we build agentic AI for offensive security?

Presented by Sudipta Acharya, PhD

Approve a 90-day pilot, not a full product build

NucleiPilot tests an LLM-assisted decision layer on top of ***Nuclei***, with code-enforced controls.

WHAT THE POC SHOWED

CONTROLLED TEST APP | PRIORITIZATION

TIE

Under a two-check budget, the LLM matched the tuned context-aware rule. No measured prioritization gain.

GRAFANA 8.3.0 | 12 GRAFANA-TAGGED CVES

F1 1.00

Template curation across three runs. Version parser: 0.29; tag-only: 0.15. One product/version, so broader validation is needed.

DECISION REQUESTED

Authorize a scoped 90-day pilot. Expand only if gains over the strongest non-AI baselines repeat across products and versions and justify cost and oversight.

Evidence from two authorized localhost demonstrations; not production validation.

Market evidence leads to one focused experiment

What exists already

Nuclei

Mature template-based security checks and filtering.

Commercial agentic testing platforms

Products such as Terra and Hadrian already advertise validation, auditability, and scope controls.

We do not claim these capabilities are missing from the market.

What NucleiPilot is designed to test

1 Evidence-guided next check

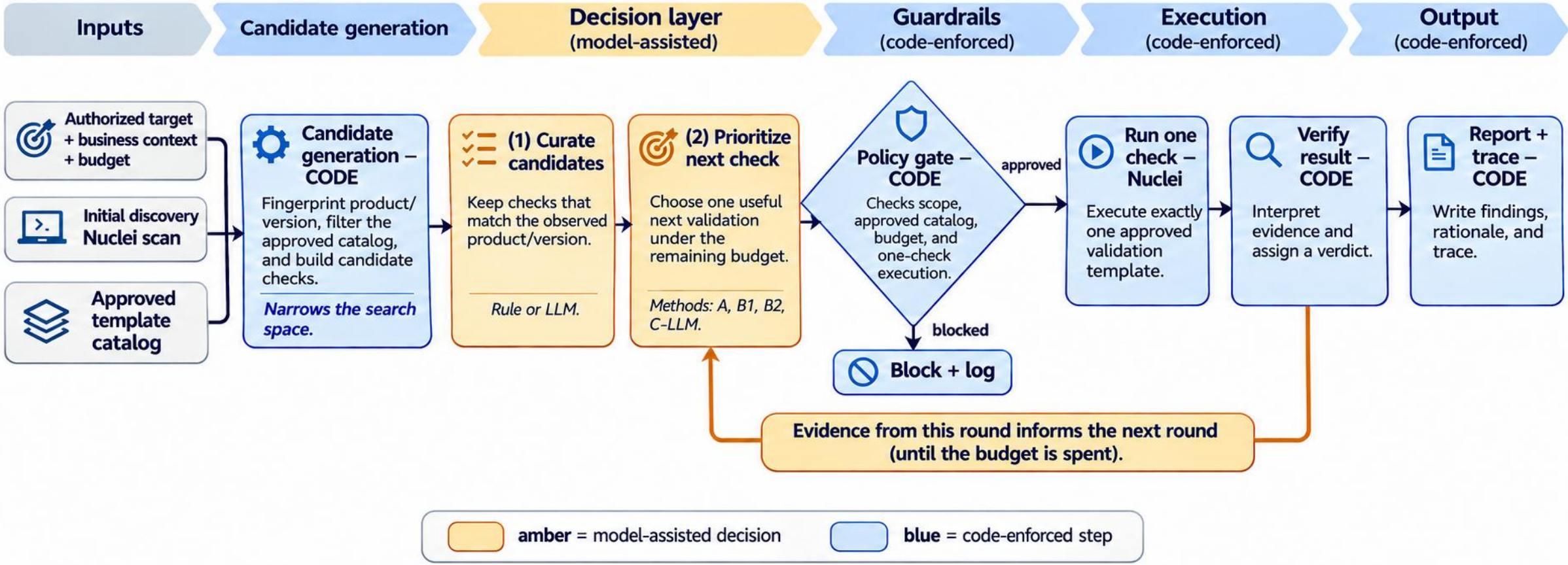
Does the planner select a useful, approved validation after an initial signal?

2 Business-aware priority

Does it allocate a limited scan budget better than severity-only and tuned context-aware rules?

Narrow question: is the LLM worth its added cost and oversight?

NucleiPilot architecture and flow



What the evidence shows

Two demonstrations on authorized localhost targets: a controlled test app and Grafana 8.3.0.

Demo 1 | Controlled test app - prioritization

Target: self-built five-endpoint localhost app; seven custom indicator-to-validation vulnerability templates.

Result: the LLM matched the tuned rule; no measured prioritization gain in this scenario.

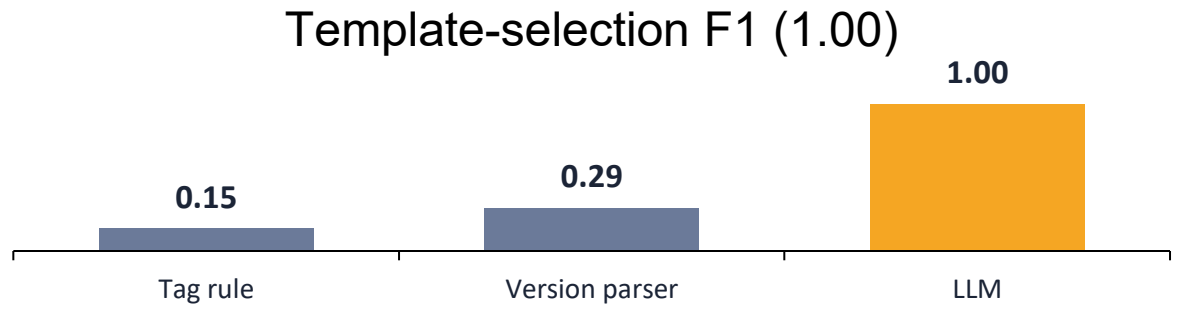
A benign /health look-alike was marked NOT_CONFIRMED. A fired template is a signal, not a verdict.

Takeaway: business context mattered more than severity in this scenario.

Demo 2 | Grafana 8.3.0 - template curation

Target: real Grafana 8.3.0 in Docker (localhost). Source: official ProjectDiscovery corpus (~14,104 templates).

Task: select the applicable CVE from 12 Grafana-tagged candidates. LLM selection F1 = 1.00 across three runs; version parser = 0.29; tag-only = 0.15.



LLM selects CVE-2021-43798 → live run → CONFIRMED (reads /etc/passwd)

- Governance: model proposes; code authorizes scope, allowlist and budget. All four deterministic safety tests produced the safe outcome.
- The Grafana result is promising but limited to one product/version; the pilot tests whether it generalizes.

From POC to a reversible investment decision

A 90-day plan with measurable gates and a clear fallback to deterministic rules.

DAYS 1-30

Reproduce & compare

Use approved targets. Compare tuned rules with the LLM. Predefine measures for accuracy, missed findings, analyst time, latency and cost.

DAYS 31-60

Add enterprise controls

Review permissions and SSO, data handling, logging, analyst approval and stop controls.

DAYS 61-90

Pilot & decide

Run on approved non-production assets. Measure outcomes against the tuned-rule baseline.

DECISION GATES

GO

Expand only if gains over the strongest non-AI baseline repeat, with acceptable cost and approved safeguards.

NO-GO

If there is no meaningful gain, retain deterministic rules. Use AI only where it adds measured value.

IMMEDIATE STOP

Halt if authorization, scope or sensitive-data controls fail.

The pilot is successful only if the AI layer adds repeatable value beyond tuned rules after accuracy, analyst effort, reliability and cost are considered.